PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Architectures des SI sensibles et Diffusion Restreinte

03-830 ANSSI - Recommandations pour les architectures des SI sensibles ou Diffusion Restreinte — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'II 901 définit les mesures de sécurité minimales pour protéger les informations sensibles, notamment celles de niveau Diffusion Restreinte.
2. Un SI de classe 2 est un système sensible physiquement isolé qui ne possède aucune connexion, même indirecte, à Internet.
3. Les journaux de sécurité d'un SI sensible doivent être conservés pendant 12 mois glissants.

Cadre et application

Notion	À retenir
Outil et versions	Guide `ANSSI-PG-075` pour appliquer l'**II 901** (**28 janvier 2015**) ; v1.2 du **24/09/2021**. « Devoir » = exigence II 901 ; « il est recommandé » = bonne pratique.

Synthèse du tri du patrimoine informationnel

Notion	À retenir
Besoin de confidentialité	Critère **primordial** (échelle des besoins, analyse de risques ; valeur modifiée par **agrégation**). Termes : **publiques** (besoin nul), **usuelles**, **sensibles**, **DR** (pas « NP »). DR : **besoin d'en connaître**.
Classes et régime	**3 classes** (annexe 2 de l'II 901) : **0** (public/usuel ou mal connecté), **1** (relié via passerelle conforme), **2** (isolé, même indirectement). Régime sensible ou DR ; risques acceptés par l'**AH** (désignée par l'AQSSI).

Les trois architectures de SI sensibles

Notion	À retenir
Physiquement isolé (classe 2)	Aucun composant partagé, **Internet impossible** ; **obligatoire si risques élevés** ; supports amovibles très encadrés (R5+).
Physiquement cloisonné (classe 1)	Aucun composant partagé, **passerelle** bidirectionnelle conforme II 901 ; si le sensible n'est **pas dominant**.
Sans SI usuel (classe 1)	Même SI, **cloisonnement logique** ; si le sensible est **dominant** ; R5− : ultime recours, entités matures ; R6 : 2 barrières logiques ; R7 : annuaires distincts.
Critères de choix	Niveau de protection (isolement > cloisonnement physique > logique), **maturité** (peu de personnel qualifié → classe 2), besoins d'interconnexion, **minimalité** des échanges.

Synthèse des interconnexions de SI sensibles

Notion	À retenir
Principes généraux	Interconnexion **inventoriée**, **homologuée**, **supervisée** ; capacités non contrôlées désactivées.
Interconnexion deux SI sensibles	R8 : **homologation spécifique**. R9 (DR) : **VPN agréés**. R11 : filtrage **côté noir** et **côté rouge** par dispositifs **qualifiés**.
SI classe 1 / classe 0	SI DR : R13 **pare-feu qualifié**, R14 **rupture de flux** entre deux pare-feux, R15 **sonde qualifiée**.
Navigation Web	Impossible en classe 2 ; R18 (classe 1) : **SI dédié** ou postes de rebond cloisonnés non persistants.
Transfert via Internet	R19/R20 : chiffrement **agréé** ou sous **visa** ; R22 : infrastructure en **DMZ** d'une passerelle classe 1.
Échanges utilisateurs	Classe 2 : flux montants par **diode** agréée. R24-R26 : protocoles autorisés, accès restreint, **jamais de compte du SI sensible** sur le système d'échanges.

Synthèse de la sécurisation des SI sensibles

Notion	À retenir
Produits/Prestataires	**R29** : prestataires sous **visa**, de préférence sur le **territoire national** ; cloud : **SecNumCloud** + II 901.
Chiffrement	Moyens **agréés** obligatoires pour toute information DR sortant d'une zone conforme.
Cloisonnement/Durcissement	**R32** : segmentation en **zones de confiance homogènes** ; **R33** : pas de moyens sensibles en zone publique.
Marquage	**R36** : mention **DIFFUSION RESTREINTE** (milieu haut/bas de page). Marquage visuel (humain) ≠ labellisation (métadonnées).
Accès/Authentification	**Compte individuel** ; comptes distincts utilisateur/admin. **R39** : authentification initiale **forte, multifacteur**.
Codes malveillants	**R42** : antivirus serveurs, postes, interconnexion (technologies diversifiées) ; mises à jour sous **24 h** ; réputation cloud **désactivée**.
Supports amovibles	**R45-R46** : limiter les supports, interdire ceux des tiers ; supports de l'entité **nominatifs**, **chiffrés**, **sous clé**.

Sécurisation des postes de travail sensibles

Notion	À retenir
Maîtrise et connexion	Configuration sous contrôle exclusif du responsable ; **hyperviseurs de type 2** interdits sauf accord ; **R49** : pas de droits admin locaux.
Architectures de poste	**Physiquement dédié** (plus sûr), **multiniveau**, ou **accès distant au SI usuel** ; jamais un poste usuel vers le sensible.
Nomadisme et sans-fil	**R54** : câble antivol, filtre ; **R59** : VPN sans `split-tunneling` ; sans-fil non de confiance (**R60** tunnel agréé, **R61** portails captifs bloqués).

Synthèse de l'administration des SI sensibles

Notion	À retenir
Généralités/Admin	**R63** : liste d'administrateurs limitée, validée par l'AH ; habilitation recommandée pour les privilèges étendus d'un SI DR.
SI d'administration	**Homologué au même niveau** que le SI administré ; architectures isolées : **deux SI distincts**.
Distance/Télémaintenance	**R64** : postes maîtrisés, **IPsec**, concentrateur dédié, **pas de split-tunneling** ; R64− : télémaintenance après analyse de risques.
Maintien en condition	**R65** : correctifs critiques sous **1 semaine**, autres sous **4 semaines** ; **R66** : isoler les systèmes obsolètes.
Journalisation/Supervision	**R68** : journaux **12 mois glissants** ; **R69** : **PDIS qualifié** ; **R70** : incidents déclarés à l'ANSSI.

Annexes : DR et visas

Notion	À retenir
DR et non DR	**DR** : mention de protection (pas une classification), sanctions **disciplinaires** ; obligations **sans contrat** (non DR : contrat). EU/NATO Restricted = classifiées.
Visas de sécurité	**Certification** (CESTI, CSPN ou CC EAL 1-7), **qualification** (recommandation de l'État, verte/orange/rouge), **agrément** (niveau d'information, ex. DR).

Pièges et confusions

- ⚠ Confondre la classe 1 (SI sensible relié à Internet par une passerelle conforme) avec la classe 2 (SI sensible physiquement isolé d'Internet).
- ⚠ Croire que Diffusion Restreinte est un niveau de classification alors que c'est une mention de protection.
- ⚠ Penser qu'une information DR peut être hébergée sur un SI sensible non homologué DR.
- ⚠ Utiliser un compte du SI sensible pour s'authentifier sur le système d'échanges sécurisés.
- ⚠ Tenter d'accéder à distance à un environnement sensible depuis un poste usuel.

Sigles et définitions

II 901	Instruction interministérielle définissant les objectifs et mesures de sécurité pour les informations sensibles.
Passerelle montante	Interconnexion permettant à un SI de classe 2 de recevoir des flux d'un SI de moindre confiance via une diode agréée.
Visa de sécurité	Attestation de l'atteinte d'un niveau de sécurité regroupant certification, qualification et agrément.
PDIS	Prestataire de détection des incidents de sécurité qualifié par l'ANSSI.

Auto-test

1. Quelle est la durée de conservation des journaux de sécurité d'un SI sensible ?
2. Quel dispositif est utilisé pour une passerelle montante vers un SI de classe 2 ?
3. Quelle est la différence entre une information publique et une information usuelle ?
4. Qu'est-ce qu'un SI de classe 0 ?
5. Qui est l'autorité chargée d'accepter formellement les risques résiduels d'un SI ?

(AH)

Réponses : **1.** 12 mois glissants · **2.** Une diode agréée par l'ANSSI · **3.** Le besoin de protection en confidentialité est nul pour la première et non nul pour la seconde · **4.** Un SI public, un SI usuel ou un SI connecté à un SI public ne respectant pas les exigences de la classe 1 · **5.** L'autorité d'homologation

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.